

Mattermost Cross Guard CDS Whitepaper

Architecture, deployment, and security analysis for cross-domain message relay

1. Executive Summary

Cross Guard is a Mattermost plugin that bridges isolated Mattermost instances across security domain boundaries using NATS or Azure Queue Storage as the transport layer. It is designed for environments where servers cannot share databases, APIs, or network access, including air-gapped networks, multi-classification deployments, and multi-tenant architectures.

The plugin relays posts, edits, deletes, and reactions bidirectionally while keeping each Mattermost server fully independent. No database synchronization, no direct API calls between servers, and no shared authentication. Each server maintains its own users, teams, channels, and data store. Cross Guard operates purely at the message level, publishing serialized envelopes to NATS subjects (or Azure queues) and consuming them on the other side.

Administrative controls enforce explicit opt-in at both the team and channel level. No messages flow until an administrator deliberately links a connection to a team and then to specific channels within that team. Inbound connections require interactive acceptance via admin prompts before any data crosses the boundary.

Transport security supports TLS 1.2+, mutual certificate authentication (mTLS), NATS authentication (token or credentials), NATS ACLs for subject-level access control, Azure Storage connection string authentication with TLS-always endpoints, and configurable permission lockdown via the `RestrictToSystemAdmins` setting.

This whitepaper provides a comprehensive technical analysis of Cross Guard's architecture, message lifecycle, security model, and deployment topologies for audiences evaluating the plugin for cross-domain use.

2. The Cross Domain Problem

What is a Cross Domain Solution?

A Cross Domain Solution (CDS) is a system that enables controlled information transfer between two or more security domains that operate at different classification levels or under different administrative authorities. In government and defense contexts, these domains are often separated by policy, regulation, or physical network segmentation. A CDS must provide a controlled, auditable, and secure pathway for information to cross these boundaries without violating the isolation guarantees of either domain.

Traditional CDS approaches include hardware guards (dedicated appliances that inspect and filter data at the network boundary), data diodes (one-way physical connections that enforce unidirectional flow), and protocol breaks (systems that terminate one protocol and re-originate data in another, preventing direct network connectivity).

These approaches work well for file transfers, email, and structured data exchange. However, they were not designed for real-time collaborative messaging. Modern collaboration tools like Mattermost operate within a single domain: users on Domain A cannot see or interact with messages on Domain B. There is no native mechanism for bridging conversations across isolated instances.

Why Existing Federation Approaches Fall Short

Several approaches exist for connecting separate Mattermost instances, but each has fundamental limitations for cross-domain use:

Approach	Mechanism	Why It Fails for CDS
Shared Database	Multiple Mattermost instances read/write from the same database	Requires direct network access between domains to the database server. Violates network isolation. The database becomes a single point of compromise spanning both domains.
Direct API Federation	Servers call each other's REST APIs to synchronize data	Requires bidirectional HTTP connectivity between servers. Violates network segmentation policies. Exposes the full Mattermost API surface across the domain boundary.
Email Bridges	Messages forwarded as emails between instances	Loses real-time conversation flow. No edit or delete synchronization. No reaction support. Latency measured in minutes, not milliseconds. Conversations become disjointed threads.

Approach	Mechanism	Why It Fails for CDS
Webhook Relays	Outgoing webhooks trigger incoming webhooks on the other server	Requires direct HTTP connectivity (same problem as API federation). Point-to-point, fragile, no built-in resilience or reconnection. No standardized authentication beyond shared secrets.

What Cross Guard Provides

Cross Guard takes a fundamentally different approach. Rather than synchronizing databases, proxying APIs, or bridging protocols, it operates as a message-level relay with a decoupled pub/sub architecture:

- **Message-level relay, not database sync:** Only individual post events (create, edit, delete, react) cross the boundary. No bulk data transfer, no schema coupling, no shared state.
- **Asynchronous, decoupled architecture:** The two Mattermost servers never communicate directly. A NATS message bus or Azure Storage account sits between them. Publishers and subscribers interact only with the transport layer, not with each other.
- **Full server independence:** Each server maintains its own users, teams, channels, database, authentication, and administration. Cross Guard adds relay capability without modifying any of these.
- **Opt-in at every level:** Relay is not automatic. Administrators must explicitly link connections to teams, then to individual channels. Inbound connections require interactive acceptance before any messages flow.
- **Minimal data crossing the boundary:** Only text content, routing metadata, and optionally file attachments transit the transport layer. File transfer is disabled by default and must be explicitly enabled per connection with configurable type filtering and size limits. User metadata, channel properties, post properties, and interactive message elements are intentionally excluded.

3. Transport Layer Options

Cross Guard supports two transport providers: NATS (pub/sub) and Azure Queue Storage (polling-based). Administrators select a provider per connection in the System Console. Both providers carry the same serialized envelope format (JSON or XML) and support the same

message types. The choice depends on infrastructure, latency requirements, and operational preferences.

NATS

What is NATS?

NATS is a lightweight, high-performance messaging system written in Go. It provides core pub/sub semantics: publishers send messages to named subjects, and subscribers receive messages from those subjects. NATS is designed for cloud-native, distributed systems and is used in production by organizations ranging from startups to government agencies.

For message relay, Cross Guard uses NATS core pub/sub, which is fire-and-forget: messages are delivered to connected subscribers in real time, with no message persistence or replay. For optional file transfer, Cross Guard uses NATS JetStream Object Store with a hardcoded bucket name of `crossguard-files` (not user-configurable, unlike Azure's `blob_container_name`). This maps directly to Cross Guard's relay model, where messages are relayed as they occur and not queued for later delivery.

Why NATS Fits the CDS Model

1. Decoupled Architecture

Publishers and subscribers never communicate directly. The NATS server mediates all traffic. Neither the publisher nor the subscriber needs to know the other's network address, identity, or even existence. This maps directly to CDS architecture where the transport sits between domains and neither domain has direct access to the other.

2. Subject-Based Routing

Messages are published to named subjects (e.g., `crossguard.relay.a-to-b`). Subscribers filter by subject. This provides natural channel isolation: different relay directions use different subjects, and NATS ACLs can restrict which clients can publish or subscribe to which subjects. No routing configuration is needed beyond subject names.

3. Lightweight Protocol

NATS uses a text-based protocol with minimal overhead. A typical Cross Guard message envelope is a few hundred bytes (JSON or XML). NATS adds negligible framing. The result is sub-millisecond publish latency, which is critical for real-time messaging where users expect near-instant delivery.

4. TLS and Authentication

NATS has native support for TLS 1.2+, token authentication, username/password authentication, and client certificate authentication (mTLS). These map directly to CDS transport security requirements. No additional proxy or TLS terminator is needed.

5. Network Placement Flexibility

A NATS server can be deployed in a DMZ, an enclave, a guard network, or any controlled network segment between domains. The Mattermost servers only need to reach the NATS server; they never need to reach each other. This is the key architectural property that enables CDS deployment.

6. Resilience

NATS clients have built-in reconnection with configurable retry behavior. Cross Guard configures unlimited reconnects with a 2-second wait, so temporary network interruptions (maintenance windows, transient failures) self-heal without manual intervention. Disconnect and reconnect events are logged for operational visibility.

7. ACL Support

NATS server authorization rules can restrict which clients can publish or subscribe to which subjects. In a CDS deployment, this means the NATS administrator can enforce that Server A can only publish to `crossguard.a-to-b` and only subscribe to `crossguard.b-to-a`, and vice versa. This provides transport-level access control independent of the plugin's own authorization.

How Cross Guard Uses NATS

Each Cross Guard connection (inbound or outbound) maps to exactly one NATS subject. Outbound connections publish serialized message envelopes to their configured subject. Inbound connections subscribe to their configured subject and dispatch received messages to type-specific handlers.

The subject prefix `crossguard.` is enforced by configuration validation. All subjects must start with this prefix, which prevents accidental cross-contamination with other NATS traffic if the NATS server is shared (though a dedicated NATS server is recommended for CDS deployments).

Separate subjects per direction (e.g., `crossguard.a-to-b` and `crossguard.b-to-a`) prevent echo loops at the transport level. Even if the plugin's application-level loop prevention were to fail, messages published on one subject are not received on a different subject.

NATS Deployment Topologies for CDS

Topology 1: Shared Network (Development)

```
Server A           NATS Server           Server B
[Plugin] -----> [ :4222 ] <----- [Plugin]
    Same network, no segmentation
```

Topology 2: DMZ Placement (Production)

```
Domain A           DMZ / Enclave           Domain B
+-----+         +-----+         +-----+
| Server A |     | NATS Server |     | Server B |
| [Plugin] |---->| [:4222]      |<----| [Plugin] |
+-----+         +-----+         +-----+
    Firewall allows only NATS (port 4222) between segments
```

Topology 3: Guard Network (Classified)

```
Classification A   Guard Appliance           Classification B
+-----+         +-----+         +-----+
| Server A |     | NATS on           |     | Server B |
| [Plugin] |---->| dedicated guard |<----| [Plugin] |
+-----+         | hardware/enclave |     +-----+
                   +-----+
    Dedicated hardware, strict firewall rules, physical separation
```

Azure Queue Storage

What is Azure Queue Storage?

[Azure Queue Storage](#) is a fully managed message queuing service provided by Microsoft Azure. It stores messages in queues that can be read by any client with a valid connection string or SAS token. Unlike NATS (which uses real-time pub/sub), Azure Queue Storage uses a polling model where consumers periodically check for new messages.

Why Azure Queue Storage Fits the CDS Model

1. Polling-Based Delivery

The plugin polls the Azure queue on a configurable interval (default 5 seconds for messages, 15 seconds for blob/file transfers). Messages are dequeued in batches of up to 32 with a 5-minute visibility timeout. This polling model is well-suited for environments where persistent

connections are difficult to maintain or where store-and-forward semantics are preferred over real-time delivery.

2. At-Least-Once Delivery

Azure Queue Storage provides at-least-once delivery semantics. Messages remain in the queue until explicitly deleted after successful processing. If the consumer crashes before acknowledging, the message becomes visible again after the visibility timeout expires. This is more durable than NATS core pub/sub, which drops messages if no subscriber is connected.

3. Managed Service

Azure Queue Storage is a fully managed service. There is no NATS cluster to deploy, patch, monitor, or scale. The Azure Storage account handles availability, replication, and maintenance. This reduces operational overhead, especially in environments where infrastructure teams prefer managed services over self-hosted components.

4. Connection String Authentication

Authentication uses an Azure Storage connection string, which contains the account name and key. The connection string is stored in the Mattermost plugin configuration (encrypted at rest by Mattermost). No separate TLS certificate management is required because all Azure Storage endpoints use TLS by default.

5. Auto-Provisioning

The plugin automatically creates the queue and blob container (as configured in `queue_name` and `blob_container_name`) on startup if they do not exist. No manual Azure resource provisioning is needed beyond creating the Storage account itself.

How Cross Guard Uses Azure Queue Storage

Each outbound connection enqueues serialized message envelopes (JSON or XML) to the configured Azure queue. File attachments (when enabled) are uploaded to the configured blob container with a key in the format `{postId}/{randomId}`, referenced in the envelope. The inbound side polls the queue, processes each message, and deletes it after successful handling. For files, the inbound side downloads the blob and deletes it after processing.

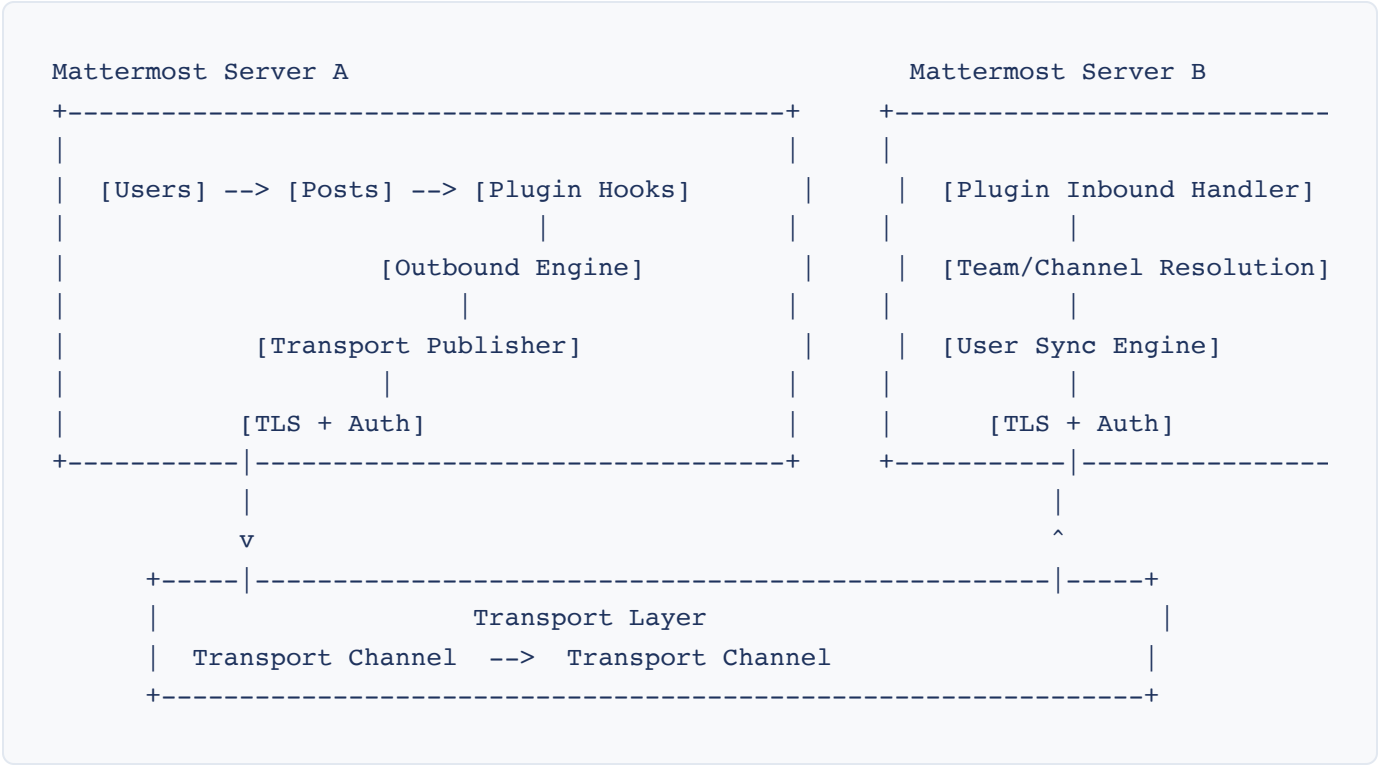
Transport Comparison

Aspect	NATS	Azure Queue Storage
Latency	Sub-millisecond (pub/sub)	5-15 seconds (polling)

Aspect	NATS	Azure Queue Storage
Delivery	At-most-once	At-least-once
Message Size	1 MB default (NATS server configurable)	48,000 bytes (before Base64)
Infrastructure	Self-hosted NATS cluster	Azure managed service
Encryption	TLS (opt-in)	TLS always (Azure endpoint)
File Transfer	JetStream Object Store (1h TTL)	Blob Storage (deleted after processing)
Best For	Low-latency, high-throughput environments	Azure-native environments, simplicity

4. System Architecture

Component Overview



Note: The specific transport mechanism depends on the configured provider. For NATS, messages flow over a NATS subject (e.g., `crossguard.a-to-b`). For Azure Queue Storage, messages flow through an Azure Storage queue.

Plugin Internal Architecture

The Cross Guard plugin is implemented as a single Go binary that runs inside the Mattermost server process. Its internal architecture consists of the following components:

- **Plugin struct:** The central struct that holds the bot user ID, KV store reference, transport provider connections (NATS or Azure), relay semaphore, wait group for goroutine lifecycle tracking, and a context for graceful shutdown.
- **Outbound pool:** A slice of `outboundConn` structs, each holding a `QueueProvider` (NATS connection or Azure client) and its configuration. Protected by a `sync.RWMutex` to allow concurrent reads (publishing) with exclusive writes (reconnection on config change).
- **Inbound pool:** A slice of `inboundConn` structs, each holding a `QueueProvider` (NATS subscription or Azure queue poller). Protected by a `sync.RWMutex` with the same read/write concurrency model.
- **Relay semaphore:** A buffered channel of capacity 256, shared by both inbound and outbound relay operations. Controls the maximum number of concurrent relay goroutines to prevent unbounded resource consumption under high message volume.
- **KV store:** Mattermost's built-in plugin key-value store, used for all persistent state (team/channel linkage, post mappings, prompt state, rewrite indexes). An optional caching layer wraps the KV store with 15-minute TTL and cluster-aware invalidation.

Plugin Lifecycle

Event	Actions
OnActivate	Creates bot user, initializes KV store and caching layer, registers the <code>/crossguard</code> slash command, initializes HTTP router for REST API and interactive prompts, creates context for shutdown signaling, spawns relay semaphore, connects all configured outbound and inbound connections (NATS or Azure Queue Storage depending on provider setting).

Event	Actions
OnConfigurationChange	Validates new configuration, closes existing transport connections, opens new connections with updated settings. Live reconnection with no plugin restart required.
OnDeactivate	Cancels context (signals all goroutines to stop), closes inbound subscriptions (stops new message delivery), waits for all in-flight relay goroutines via WaitGroup, closes outbound connections.

5. Message Relay Lifecycle (Outbound)

This section traces the complete path of a message from the moment a user posts in a channel on Server A to the moment it is published to the transport layer (NATS or Azure Queue Storage).

Step 1: Post Lifecycle Hook Fires

Mattermost's plugin API provides lifecycle hooks that fire after post events. Cross Guard implements five hooks in `hooks.go`:

- `MessageHasBeenPosted()` for new posts
- `MessageHasBeenUpdated()` for edits
- `MessageHasBeenDeleted()` for deletes
- `ReactionHasBeenAdded()` for new reactions
- `ReactionHasBeenRemoved()` for reaction removals

Each hook receives the relevant post or reaction object from Mattermost and begins the relay evaluation pipeline.

Step 2: Filtering (What Does NOT Get Relayed)

Before any relay occurs, the hook applies a series of filters to determine whether the event should be relayed. Events that match any filter are silently skipped:

Filter	Check	Purpose
System messages	<code>post.IsSystemMessage()</code> returns true	Prevents system-generated messages (join/leave, header change, etc.) from relaying
Bot posts	<code>post.UserId == p.botUserID</code>	Prevents bot announcements (init, teardown, prompts) from relaying
Already-relayed posts	<code>post.GetProp("crossguard_relayed") != nil</code>	Primary loop prevention: stops inbound posts from being re-relayed outbound
Sync user reactions	<code>user.Position == "crossguard-sync"</code>	Prevents reactions added by sync users from being relayed back

Note: Not all filters apply to every hook. The system message and `crossguard_relayed` checks apply to post create and update hooks. The delete hook uses bot user ID and a deleting flag instead. Reaction hooks use bot user ID and sync-user position filtering.

Step 3: Channel and Team Validation

The `isChannelRelayEnabled()` function checks whether the channel and its parent team are linked to any outbound connections:

1. Look up the channel's linked connections from the KV store (key: `crossguard-channelinit-{channelID}`)
2. Look up the team's linked connections from the KV store (key: `crossguard-teaminit-{teamID}`)
3. Return the channel connections after verifying the team also has connections. The effective intersection happens at publish time via `isOutboundLinked()` .

If no connections match, the message is not relayed. This ensures that both team-level and channel-level opt-in are required.

Step 4: Envelope Construction

The hook fetches source metadata (user, channel, team) via the Plugin API and builds a type-specific payload:

Message Type	Payload Fields
<code>crossguard_post</code> / <code>crossguard_update</code>	<code>post_id</code> , <code>root_id</code> , <code>channel_id</code> , <code>channel_name</code> , <code>team_id</code> , <code>team_name</code> , <code>user_id</code> , <code>username</code> , <code>message</code> , <code>create_at</code>
<code>crossguard_delete</code>	<code>post_id</code> , <code>channel_id</code> , <code>channel_name</code> , <code>team_id</code> , <code>team_name</code>
<code>crossguard_reaction_add</code> / <code>crossguard_reaction_remove</code>	<code>post_id</code> , <code>channel_id</code> , <code>channel_name</code> , <code>team_id</code> , <code>team_name</code> , <code>user_id</code> , <code>username</code> , <code>emoji_name</code>

The payload is embedded in a `model.Envelope` struct with a type constant and an RFC 3339 UTC timestamp, then serialized via `model.Marshal()` to JSON or XML bytes depending on the connection's `message_format` setting.

Step 5: Semaphore Acquisition and Async Dispatch

The relay operation is dispatched asynchronously to avoid blocking the Mattermost post lifecycle:

1. Non-blocking attempt to acquire a slot from the relay semaphore (buffered channel of capacity 256)
2. If the semaphore is full (256 concurrent relays already in progress): drop the message and log a warning. This is a deliberate design choice to prevent unbounded goroutine spawning.
3. If a slot is acquired: increment the WaitGroup counter and spawn a goroutine for the publish operation

Step 6: Publish to Transport

Inside the goroutine, for each outbound connection whose name matches a linked connection from Step 3:

1. Check connection health via application-level tracking (success/failure of recent publishes, rechecked every 30 seconds). If unhealthy, skip the connection silently.
2. Call `provider.Publish(ctx, data)` with the serialized bytes (JSON or XML, per connection config)
3. Provider-specific behavior: NATS checks `IsConnected()` / `IsReconnecting()` , retries up to 3 times with exponential backoff (500ms, 1s, 2s), and flushes. Azure enqueues as Base64 without

application-level retries.

4. On failure: log an error and drop the message (no queuing)
5. Context cancellation is respected during backoff waits for graceful shutdown

After publishing (or dropping), the semaphore slot is released and the WaitGroup counter is decremented.

6. Message Relay Lifecycle (Inbound)

This section traces the complete path of a message from the moment it arrives via the transport layer (NATS subject or Azure queue) to the moment it appears as a local post on Server B.

Step 1: Transport Delivers Message

The `handleInboundMessage()` closure receives raw bytes (`[]byte`) from the transport provider (NATS subscription callback or Azure queue poller). Like outbound, it performs a non-blocking semaphore acquisition from the same 256-slot pool. If the semaphore is full, the message is dropped with a warning log. If a slot is acquired, a goroutine is spawned.

Step 2: Envelope Deserialization

`model.DetectFormat(data)` auto-detects the wire format (JSON or XML) by inspecting the first non-whitespace byte, then `model.Unmarshal()` decodes the envelope. The handler dispatches by `envelope.Type` :

Type	Handler
<code>crossguard_post</code>	<code>handleInboundPost()</code>
<code>crossguard_update</code>	<code>handleInboundUpdate()</code>
<code>crossguard_delete</code>	<code>handleInboundDelete()</code>
<code>crossguard_reaction_add</code>	<code>handleInboundReaction(add=true)</code>
<code>crossguard_reaction_remove</code>	<code>handleInboundReaction(add=false)</code>

Type	Handler
<code>crossguard_test</code>	Log and discard (connection testing)

Step 3: Team and Channel Resolution

The `resolveTeamAndChannel()` function maps the remote team and channel names to local entities:

- 1. Check rewrite index first:** `GetTeamRewriteIndex(connName, remoteTeamName)` looks up KV key `crossguard-rwi-{connName}::{remoteTeamName}`. If a rewrite rule exists, use the local team ID from the index.
- 2. If no rewrite:** `GetTeamByName(teamName)` assumes the remote and local team names match.
- 3. Verify team linkage:** Check KV store (`crossguard-teaminit-{teamID}`) to confirm this team is linked to the inbound connection.
- 4. If not linked:** Trigger `handleUnlinkedInbound()`, which posts an Accept/Block prompt to `#town-square`. The message is dropped (it will not be retried).
- 5. Resolve channel:** `GetChannelByName(teamID, channelName)` to find the local channel.
- 6. Verify channel linkage:** Check KV store for channel-level connection linkage.
- 7. If channel not linked:** Trigger `handleUnlinkedInboundChannel()`, which posts a prompt in the channel itself. The message is dropped.

Step 4: User Resolution

The `resolveInboundUser()` function determines which local user will be the author of the relayed post. This is governed by the `UsernameLookup` setting:

- If UsernameLookup enabled (default):** Call `GetUserByUsername(username)`. If a matching local user is found and their `Position` is not `"crossguard-sync"`, use the real local user. Messages appear as if that user posted them.
- If not found or lookup disabled:** Create or fetch a synthetic "sync user" with:
 - Username: `{remoteUsername}.{connName}` (truncated to 64 characters)
 - Email: `crossguard.synthetic_user.{randomID}@crossguard.local`
 - Position: `crossguard-sync`
 - FirstName: remote username
 - LastName: (via `{connName}`)

- Props: `CrossguardRemoteUsername: {originalUsername}`
- **Race-safe creation:** Uses atomic create with retry on conflict. If two messages arrive simultaneously for the same unknown user, only one sync user is created.

After user resolution, `ensureMembership()` adds the user to the target team and channel if they are not already a member.

Step 5: Post Creation (New Posts)

1. Build a `mmModel.Post` with the resolved user ID, channel ID, and message text
2. If threaded (`RootID` present in envelope): look up the local root post via post mapping to preserve thread structure
3. Set `post.AddProp("crossguard_relayed", true)` to prevent re-relay (primary loop prevention)
4. Call `p.API.CreatePost(post)` to create the post locally
5. Store the mapping: `SetPostMapping(connName, remotePostID, localPostID)` for future edits/deletes

Step 5 (alt): Post Update

1. Look up local post ID via `GetPostMapping(connName, remotePostID)`
2. If no mapping exists: log a warning and skip (the original post may not have been relayed, e.g., if the channel was linked after the original was posted)
3. Fetch the local post, replace the `Message` field, call `UpdatePost()`

Step 5 (alt): Post Delete

1. Look up local post ID via post mapping
2. Set `SetDeletingFlag(localPostID)` in KV store (prevents the `MessageHasBeenDeleted` hook from re-relaying this delete)
3. Call `DeletePost(localPostID)`
4. Clear `ClearDeletingFlag(localPostID)`
5. Delete the post mapping entry

Step 5 (alt): Reaction Add/Remove

1. Look up local post ID via post mapping
2. Resolve user (same logic as for posts)
3. Call `AddReaction()` or `RemoveReaction()` with the local user ID and post ID

7. Data Boundary Control

Understanding exactly what data crosses the domain boundary is critical for CDS evaluation. This section documents every field in the transport envelope, its source, whether it is user-controlled, and how it is used on the receiving side. The envelope format is identical for NATS and Azure Queue Storage providers.

Data That Crosses the Boundary (Transport Envelope)

Envelope Fields

The envelope is a single-layer structure (payloads are embedded directly, not serialized as strings). It may be serialized as JSON or XML depending on the outbound connection's `message_format` setting.

Field	Content	User-Controlled?	Used For
<code>type</code>	Message type constant (e.g., <code>crossguard_post</code>)	No (set by plugin code)	Handler dispatch
<code>timestamp</code>	RFC 3339 UTC timestamp	No (set by plugin code)	Logging only
<code>post_message</code>	Post or update payload	Contains user-controlled fields (see below)	Create or update a post
<code>delete_message</code>	Delete payload	No (IDs only)	Delete a post
<code>reaction_message</code>	Reaction payload	Partially (emoji name is user-selected)	Add or remove a reaction
<code>test_message</code>	Test payload	No (generated ID)	Connectivity verification

PostMessage Payload Fields

Field	Source	User-Controlled?	Used On Receive
<code>post_id</code>	<code>post.Id</code> (26-char Mattermost ID)	No	Post mapping key for edits/deletes
<code>root_id</code>	<code>post.RootId</code>	No	Thread parent resolution via post mapping
<code>channel_id</code>	<code>post.ChannelId</code>	No	Not used directly (name-based routing)
<code>channel_name</code>	<code>channel.Name</code>	Indirectly (admin-set)	Routing: <code>GetChannelByName()</code>
<code>team_id</code>	<code>channel.TeamId</code>	No	Not used directly
<code>team_name</code>	<code>team.Name</code>	Indirectly (admin-set)	Routing: <code>GetTeamByName()</code> or rewrite lookup
<code>user_id</code>	<code>post.UserId</code>	No	Not used on receive
<code>username</code>	<code>user.Username</code>	Yes (users choose usernames)	User resolution: <code>resolveInboundUser()</code>
<code>message</code>	<code>post.Message</code>	Yes (full post content)	Post body text
<code>create_at</code>	<code>post.CreateAt</code>	No	Not used on receive

DeleteMessage Payload Fields

Contains `post_id`, `channel_id`, `channel_name`, `team_id`, `team_name`. No user-controlled content beyond the admin-set team and channel names.

ReactionMessage Payload Fields

Contains `post_id`, `channel_id`, `channel_name`, `team_id`, `team_name`, `user_id`, `username` (user-controlled), and `emoji_name` (user-selected from Mattermost's emoji set).

Data Intentionally Excluded

Minimal data boundary

Cross Guard intentionally excludes the following from the relay envelope. This minimizes the attack surface and prevents accidental data spillage.

Excluded Data	Why Excluded
File attachments (<code>post.FileIds</code>)	File transfer is disabled by default. When enabled per connection, files are uploaded to a NATS JetStream Object Store (NATS provider) or Azure Blob Storage (Azure provider) and downloaded by the receiving side. For Azure Blob Storage, blobs are stored with the key format <code>{postId}/{randomId}</code> , where <code>postId</code> is the Mattermost post ID and <code>randomId</code> is a newly generated unique identifier. Administrators can restrict transfers using allow/deny file type filtering and a 100 MB size limit. Files may contain embedded metadata or classified content, so explicit opt-in and filtering are required.
Post properties (<code>post.Props</code>)	Props may contain plugin-specific data from other plugins (webhooks, integrations, custom metadata). Relaying them could leak internal system information.
User metadata (email, profile image, custom fields, roles, auth data)	User profiles may contain PII, classification markings, or organizational data that should not cross domain boundaries.
Channel metadata (purpose, header, type)	Channel headers may contain sensitive operational information. Public/private distinction is not meaningful across domains.
Hashtags, pinned status, edit history	Operational metadata that adds attack surface without proportional value.
Interactive message elements (buttons, menus)	Interactive elements contain callback URLs and action IDs that reference the source server's internal state. Relaying them would create non-functional UI elements or potential SSRF vectors.
File previews, embedded links, Open Graph data	Preview data may contain fetched content from the source domain's network, which should not be exposed to the receiving domain.

8. User Identity Across Domains

Cross Guard supports two identity models for how inbound messages are attributed to local users. The choice between them is a security/usability tradeoff controlled by the `UsernameLookup` plugin setting.

Model 1: Username Lookup (Default, UsernameLookup=true)

Behavior	Inbound messages are posted as the matching local user if a user with the same username exists on the receiving server.
Advantage	Seamless user experience. Messages appear to come from the "right" person. No visual distinction between local and relayed posts.
Risk	If Remote Domain A has a user "jsmith" and Local Domain B also has "jsmith", messages from Remote jsmith appear as if Local jsmith wrote them. This is username impersonation if the two accounts belong to different people.
Appropriate When	The same identity provider (LDAP, Active Directory, SSO) provisions users on both servers, so a username match implies the same person.

Model 2: Sync Users (UsernameLookup=false, or No Match Found)

Behavior	A synthetic "sync user" is created with a munged username (e.g., <code>alice.relay-from-a</code>). All inbound messages from that remote user are posted under this sync user.
Sync User Properties	<code>Position="crossguard-sync"</code> , <code>LastName="(via connName)"</code> , <code>Props.CrossguardRemoteUsername=original</code>
Advantage	Clear visual distinction between local and relayed users. No impersonation risk. The webapp <code>UserPopover</code> component shows "Relayed from: alice (via relay-from-a)" when hovering over the sync user.
Appropriate When	Usernames do not match across domains, or when impersonation risk is unacceptable (recommended for CDS deployments).

Hybrid Behavior

When username lookup is enabled, resolution is per-message. If a matching local user exists, that user is used. If no match is found, a sync user is created for that specific remote username. This

means messages in the same channel may appear from a mix of real local users and sync users, depending on which remote usernames have local matches.

9. Connection Management and Administrative Workflows

Connection Configuration (System Console)

Transport connections are configured in the Mattermost System Console under **Plugins > Cross Guard**. Inbound and outbound connections are configured as JSON arrays. Each connection specifies a provider type (NATS, Azure Queue Storage, or Azure Blob Storage) along with provider-specific settings:

- **name:** Unique identifier, lowercase alphanumeric with hyphens (e.g., `relay-to-server-b`)
- **provider:** Transport provider type (`"nats"` , `"azure-queue"` , or `"azure-blob"`). Provider-specific fields are nested under the corresponding key.

NATS Provider Fields (nested under `"nats"`)

- **address:** NATS server address (e.g., `nats://nats:4222`)
- **subject:** NATS subject to publish/subscribe (must start with `crossguard.`)
- **TLS settings:** `tls_enabled` , `client_cert` , `client_key` , `ca_cert`
- **Auth settings:** `auth_type` (`none` , `token` , or `credentials`), plus type-specific fields

Azure Queue Provider Fields (nested under `"azure_queue"`)

- **queue_service_url:** Azure Queue Storage service URL (e.g., `https://<account>.queue.core.windows.net`)
- **blob_service_url:** Azure Blob Storage service URL, required when `file_transfer_enabled` is `true`
- **account_name / account_key:** Shared-key credentials (treated as secrets, encrypted at rest by Mattermost)
- **queue_name:** Name of the Azure Storage queue (user-configurable, created automatically if it does not exist)
- **blob_container_name:** Name of the Azure Blob container for file transfers (user-configurable, created automatically if it does not exist)

Azure Blob Provider Fields (nested under `"azure_blob"`)

- **service_url:** Azure Blob Storage service URL
- **account_name / account_key:** Shared-key credentials (treated as secrets, encrypted at rest by Mattermost)
- **blob_container_name:** Container that holds both batch WAL blobs and deferred file blobs (auto-created if missing)
- **flush_interval_seconds:** Interval at which the outbound WAL buffer is sealed and uploaded as a batch blob. Default 60 seconds, minimum 5.
- **blob_lock_max_age_seconds:** Maximum lease age before a stall is broken by another inbound poller. Default 300 seconds, minimum 30.

Configuration changes trigger live reconnection. The plugin closes existing transport connections and opens new ones with the updated settings. No plugin restart is required.

Team Initialization Workflow

- 1 **Admin runs** `/crossguard init-team [connection-name]` in the team to be linked. If only one connection exists, it is auto-selected. If multiple exist, an interactive dialog with a dropdown is presented.
- 2 **Connection linked to team:** The connection is stored in the KV store using an atomic compare-and-set (CAS) operation to prevent race conditions.
- 3 **Announcement posted:** The bot posts in `#town-square` : "Cross Guard connection outbound:relay-to-b linked to this team by @admin."
- 4 **Global tracking updated:** The team ID is added to the global initialized teams list for status reporting.

Channel Initialization Workflow

- 1 **Admin runs** `/crossguard init-channel [connection-name]` in the channel. The slash command requires the team to be initialized first via `/crossguard init-team` . The REST API auto-links the team if needed.
- 2 **Connection linked to channel:** Stored in KV store via CAS operation.

- 3 **Visual indicator added:** Channel header is updated with a link emoji prefix for visual indication of relay status.
- 4 **WebSocket event published:** The webapp receives a notification to update channel indicators in real time.
- 5 **Announcement posted:** Bot posts a confirmation in the channel.

Inbound Acceptance Workflow

When the first inbound message arrives for an unlinked team or channel, the plugin does not silently create the link. Instead, it presents an interactive prompt to administrators:

1. Bot posts an interactive message with Accept and Block buttons to `#town-square` (for team-level) or the target channel (for channel-level)
2. Only one prompt is created per team-connection pair (idempotent via KV store check)
3. A Team Admin or System Admin clicks Accept: the connection is auto-linked, and the prompt is replaced with a success message
4. If Block is clicked: the prompt state is set to "blocked" and no messages flow until `/crossguard reset-prompt` clears it
5. The same flow repeats at the channel level once the team is accepted

Team Name Rewriting

For environments where the remote and local team names differ (common in multi-domain deployments where each domain has its own naming conventions):

- `/crossguard rewrite-team [connection] [remote-team-name]` creates a mapping from the remote team name to the local team where the command is run
- Stored as a reverse index in KV: `crossguard-rwi-{connName}:::{remoteTeamName}` maps to the local team ID
- Conflict detection: the same remote team name cannot map to two different local teams (returns HTTP 409)
- Audit trail: bot posts in `#town-square` showing who set or cleared the rewrite

Teardown Workflow

- `/crossguard teardown-channel` and `/crossguard teardown-team` unlink connections
- Removes the link emoji from the channel header
- Posts a farewell announcement
- Does not cascade: `teardown-team` does not automatically teardown channels within the team

10. Loop Prevention Architecture

The Loop Problem

Relay loops are the most critical failure mode for any message relay system. Without prevention, the following cycle occurs:

1. Server A user posts a message
2. Cross Guard on Server A relays the message to Server B via the transport layer
3. Cross Guard on Server B creates the post locally via the Plugin API
4. This triggers Server B's `MessageHasBeenPosted` hook
5. Without prevention: Server B would relay the message back to Server A via the transport layer
6. Server A receives it, creates it locally, triggering its own hook
7. Infinite loop: messages multiply exponentially

Cross Guard uses four independent mechanisms to prevent this, following a defense-in-depth approach where no single mechanism is solely responsible.

Mechanism 1: `crossguard_relayed` Post Property (Primary)

- Every inbound post is created with `post.AddProp("crossguard_relayed", true)`
- Every outbound hook checks `post.GetProp("crossguard_relayed") != nil` and skips if present
- This defense applies to post create and update hooks. Delete hooks use a separate deleting flag mechanism, and reaction hooks use sync-user position filtering.

Mechanism 2: Bot User Filtering (Secondary)

- All outbound hooks check `post.UserId == p.botUserID` and skip bot posts
- Prevents bot announcements (init/teardown messages, interactive prompts) from being relayed

- Also provides loop protection if a relayed post were somehow attributed to the bot user

Mechanism 3: Sync User Reaction Filtering (Tertiary)

- Reaction hooks check `user.Position == "crossguard-sync"` and skip sync user reactions
- When an inbound reaction is added by a sync user, the local reaction hook fires but is filtered out
- Prevents reaction loops that would otherwise occur with sync users

Mechanism 4: Delete Flag (Delete-Specific)

- Problem: inbound delete calls `DeletePost()`, which fires the `MessageHasBeenDeleted` hook
- Solution: before deleting, set `SetDeletingFlag(localPostID)` in the KV store
- The outbound delete hook checks `IsDeletingFlagSet(post.Id)` and skips if set
- Flag is cleared after the delete completes
- Prevents infinite delete-relay loops

Defense in Depth

Multiple independent mechanisms

These four mechanisms operate independently. Even if the `crossguard_relayed` property were somehow lost (e.g., a Mattermost bug stripping props), bot user filtering would catch bot-posted messages. Even if a race condition occurred in the delete flag, the post property check would catch the re-relay attempt. No single failure mode can cause a loop.

11. Transport Security Configuration

NATS Transport Security

TLS Configuration

- Minimum TLS 1.2 enforced (hardcoded `tls.VersionTLS12` in the NATS connection options)
- Connection fields: `tls_enabled` (boolean), `client_cert` (file path), `client_key` (file path), `ca_cert` (file path)

- Client certificate and key must be provided together (validation enforced at configuration time)
- CA certificate enables server certificate verification (the plugin verifies the NATS server's identity)

Authentication Options

Method	Configuration	Description	Suitable For
<code>none</code>	No additional fields	No NATS authentication. Anyone who can reach the NATS server can publish and subscribe.	Development and testing only
<code>token</code>	<code>token</code> field	Bearer token sent on NATS connection. Shared secret between the plugin and the NATS server.	Production environments with simple auth requirements
<code>credentials</code>	<code>username</code> + <code>password</code> fields	Username and password sent on NATS connection. Allows per-client identity on the NATS server.	Production and CDS environments requiring per-client ACLs

Connection Resilience

- Persistent connections with unlimited reconnects (`MaxReconnects = -1`)
- 2-second reconnect wait between attempts
- Disconnect events logged at WARN level, reconnect events at INFO level
- Context-aware cancellation: reconnection attempts are abandoned during graceful plugin shutdown

Outbound Publish Reliability

- 3 retry attempts with exponential backoff (500ms, 1s, 2s)
- Each publish followed by a flush call to confirm delivery to the NATS server
- Messages are dropped (not queued) after retry exhaustion
- Context cancellation is respected during backoff waits

Configuration Validation

- **Connection names:** lowercase alphanumeric with hyphens, unique across all connections (both inbound and outbound)

- **Subject:** must start with `crossguard.` prefix (prevents accidental subscription to unrelated NATS traffic)
- **Auth type:** must be `none` , `token` , or `credentials`
- **Conditional fields:** token required for token auth, username and password required for credentials auth

Deployment Sensitivity Guide

Level	TLS	Auth	mTLS	Dedicated NATS	ACLs
Development	Optional	Optional	No	No	No
Production	Required	Token or credentials	Recommended	Recommended	Recommended
CDS (classified)	Required	Credentials	Required	Required	Required

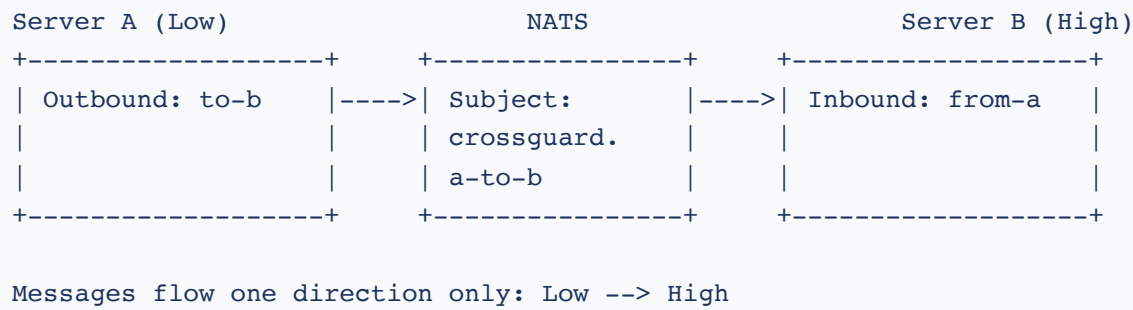
Azure Transport Security

- **Connection String:** The connection string contains the account key and must be treated as a secret. It is stored in the Mattermost plugin configuration (encrypted at rest by Mattermost).
- **Network Security:** Azure Storage supports Virtual Network service endpoints and private endpoints to restrict access to specific networks.
- **Encryption:** All Azure Storage traffic uses TLS. Data at rest is encrypted by Azure Storage Service Encryption (SSE).
- **Access Control:** Use Azure RBAC or shared access signatures (SAS) for fine-grained access control in production. The plugin currently uses connection string (shared key) authentication.

12. Deployment Topologies

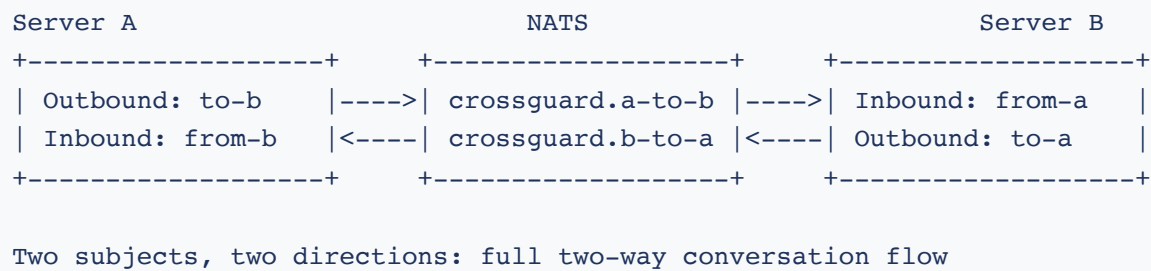
Cross Guard supports multiple deployment topologies depending on the number of servers, the direction of message flow, the transport provider, and the network architecture between domains. The NATS topologies below apply to NATS-based deployments. Azure Queue Storage topology follows.

Topology 1: Unidirectional Relay (Low-to-High)



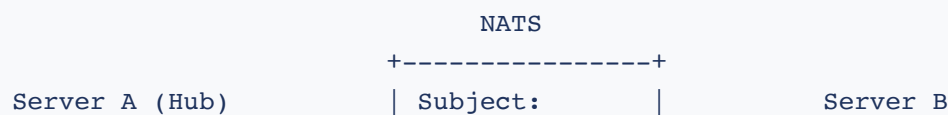
- Server A has one outbound connection; Server B has one inbound connection
- Same NATS subject configured on both sides
- Messages flow from the low-side to the high-side only
- Use case: low-side collaboration visible on high-side for monitoring or awareness

Topology 2: Bidirectional Relay



- Each server has one outbound and one inbound connection
- Different NATS subjects per direction prevents echo at the transport level
- Full two-way conversation flow between domains
- Use case: collaborative communication between domains

Topology 3: Hub-and-Spoke (Multi-Server Broadcast)



```

+-----+ | crossguard. | +-----+
| Outbound: to-all |-->| hub-broadcast |-->| Inbound: from-hub |
+-----+ |             | +-----+
          |             |
          |             | Server C
          |             | +-----+
          |             | |-->| Inbound: from-hub |
          |             | +-----+
          |             |
          |             | Server D
          |             | +-----+
          |             | |-->| Inbound: from-hub |
          |             | +-----+
+-----+ +-----+

```

One publisher, multiple subscribers on the same subject

- Server A publishes; Servers B, C, D subscribe to the same subject
- NATS delivers to all subscribers automatically
- Use case: broadcast from one domain to many receiving domains

Topology 4: Loopback (Same-Server Relay)

```

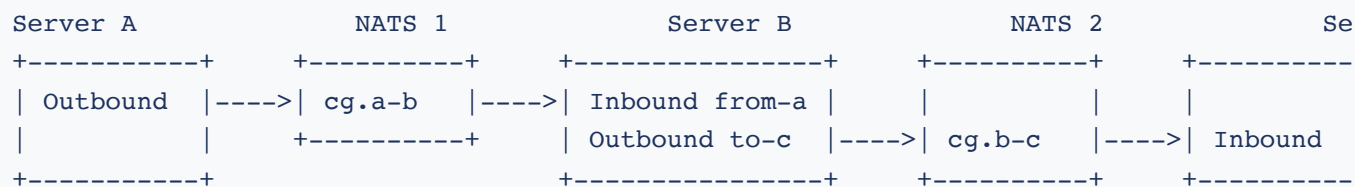
Server A
+-----+
| Outbound: loopback --> NATS --> Inbound: loopback |
|                                                     |
| Team "source-team"                                |
|   Channel: #ops-updates                            |
|   |                                                 |
|   Team Name Rewrite:                              |
|   "source-team" --> "dest-team" (local)            |
|   |                                                 |
| Team "dest-team"                                   |
|   Channel: #ops-updates                            |
+-----+

```

Both connections on the same server, team name rewrite routes between teams

- Both outbound and inbound connections on the same server, same NATS subject
- Requires team name rewrite to route messages from one team to another
- Use case: internal relay between isolated project teams on the same server

Topology 5: Multi-Hop Relay

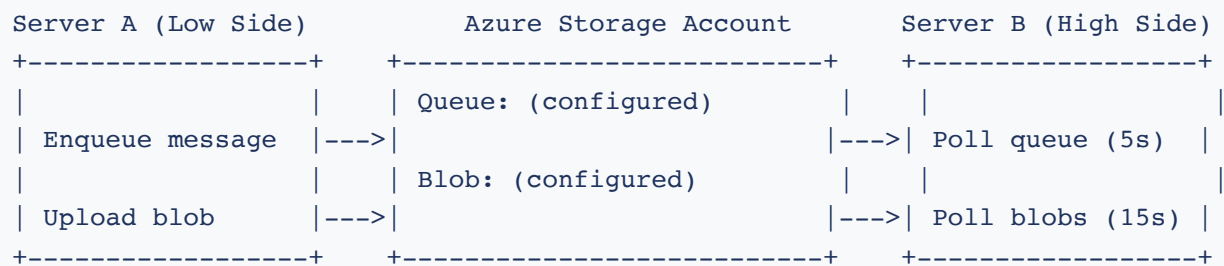


Server B acts as a relay point. Each hop is independent.

- Server B receives from A and re-relays to C
- Each hop is an independent Cross Guard configuration with its own connections
- Messages on Server B are full local posts (editable, deletable, visible to Server B users)
- Use case: cascading classification levels (e.g., Unclassified to Secret to Top Secret)

Azure Queue Storage Topology

In Azure-native deployments, both Mattermost instances connect to a shared Azure Storage account. The outbound server enqueues messages and uploads file blobs. The inbound server polls the queue and blob container. No additional infrastructure (NATS cluster, JetStream) is required.



13. State Management and Persistence

Cross Guard stores all persistent state in Mattermost's built-in plugin KV store. No external database is required. All state is key-value pairs accessed via the Plugin API.

KV Key Schema

Key Pattern	Value	Purpose
crossguard-teaminit-{teamID}	[]TeamConnection (JSON array)	Which connections are linked to this team
crossguard-channelinit-{channelID}	[]TeamConnection (JSON array)	Which connections are linked to this channel
crossguard-initialized-teams	[]string (team IDs)	Global list of initialized teams for status reporting
pm-{connName}-{remotePostID}	string (local post ID)	Maps remote post IDs to local post IDs for edits/deletes
crossguard-deleting-{localPostID}	true	Flag set during inbound delete to prevent loop
crossguard-connprompt-{teamID}-{connName}	ConnectionPrompt (JSON)	Team-level inbound acceptance prompt state
crossguard-chanprompt-{channelID}-{connName}	ConnectionPrompt (JSON)	Channel-level inbound acceptance prompt state
crossguard-rwi-{connName}::{remoteTeamName}	string (local team ID)	Team name rewrite reverse index

Caching Layer

An optional caching layer wraps the base KV store to reduce API calls for frequently accessed data:

Cache	Size	TTL	Invalidation Event
Team connections	64 entries	15 minutes	cache_inv_teaminit
Channel connections	1024 entries	15 minutes	cache_inv_chaninit
Initialized teams list	1 entry	15 minutes	cache_inv_initteams
Rewrite index	256 entries	15 minutes	cache_inv_rwindex

The cache is cluster-aware: write operations publish invalidation events to all cluster nodes via `PluginClusterEvent`. This ensures cache consistency in multi-node Mattermost deployments.

CAS Operations

List modifications (adding or removing a team connection, channel connection, or initialized team) use atomic compare-and-set (CAS) with 5 retries. This prevents race conditions when multiple admin actions occur simultaneously. All modifications have all-or-nothing semantics (no partial updates).

14. Concurrency Model

Relay Semaphore

The relay semaphore is a buffered channel of capacity 256, shared by both inbound and outbound relay operations. It provides backpressure to prevent unbounded goroutine spawning under high message volume:

- Non-blocking acquisition: if the semaphore is full, the message is dropped with a warning log rather than blocking
- Each relay operation: acquire slot, spawn goroutine, process message, release slot
- The drop-when-full policy ensures the Mattermost server process is never starved of resources by relay operations

File Transfer Semaphore

A separate file transfer semaphore (buffered channel of capacity 32) controls concurrent file upload and download operations. This prevents file transfers from consuming excessive bandwidth or memory:

- Outbound file uploads use non-blocking acquisition: if all 32 slots are in use, the file upload is skipped for that message
- Inbound file downloads use blocking acquisition: the goroutine waits until a slot becomes available before downloading
- This asymmetry ensures inbound files are reliably downloaded while outbound uploads do not block message relay

Goroutine Lifecycle

- All relay goroutines are tracked via a `sync.WaitGroup`
- Context cancellation signals shutdown to all goroutines
- OnDeactivate sequence: cancel context, close inbound subscriptions, wait for all goroutines, close outbound connections
- This ensures no orphaned goroutines remain after plugin deactivation

Connection Pool Protection

Resource	Lock Type	Read Lock (Concurrent)	Write Lock (Exclusive)
Outbound connections	<code>sync.RWMutex</code>	Publishing messages	Reconnection on config change
Inbound connections	<code>sync.RWMutex</code>	Subscription access	Reconnection on config change
Configuration	<code>sync.RWMutex</code>	Reading current config	Config update

NATS Client Concurrency

The NATS Go client is goroutine-safe for publish operations. Subscription callbacks run in separate NATS-managed goroutines. Cross Guard wraps these callbacks with semaphore control to limit the total number of concurrent relay operations across both directions.

15. Operational Monitoring and Troubleshooting

Key Log Messages

Level	Message	Meaning	Action
WARN	"Relay semaphore full, dropping inbound message"	Message volume exceeds processing capacity	Check for message flood or consider scaling

Level	Message	Meaning	Action
WARN	(no log message, connection silently skipped)	Outbound connection is unhealthy (health check failed)	Check transport server health and network connectivity. The connection will be rechecked after 30 seconds.
WARN	"Inbound update: no post mapping found"	Edit/delete arrived for a post that was not previously relayed	Expected if channel was linked after the original post
WARN	"Unknown inbound message type"	Unexpected envelope type received	Investigate possible message injection or version mismatch
ERROR	"Failed to publish to outbound after retries"	Transport unreachable after retry attempts	Check transport server, network, TLS certificates
ERROR	"Inbound post: create failed"	Mattermost API rejected the post creation	Check post content, channel permissions, server health
INFO	"Inbound NATS reconnected"	NATS connection recovered after interruption (NATS provider only; Azure uses polling, so there are no reconnect events)	Normal recovery, verify message flow resumed
INFO	"Outbound NATS reconnected"	NATS connection recovered after interruption (NATS provider only; Azure uses polling, so there are no reconnect events)	Normal recovery, verify message flow resumed

Status Commands

- `/crossguard status` : Shows team and channel linkage state. System Admins see a global overview across all teams and connections. Team members see their team/channel status.

REST API Status Endpoints

Endpoint	Permission	Returns
GET /api/v1/status	System Admin	Global status with all teams, connections, and warnings
GET /api/v1/teams/{id}/status	Team member	Team-specific status including orphaned connections
GET /api/v1/channels/{id}/status	Channel member	Channel-specific status

Connection Testing

POST /api/v1/test-connection (System Admin only) tests transport connectivity without affecting running connections:

- Outbound test: publishes a test message and confirms the flush succeeds
- Inbound test: subscribes to the subject and confirms the subscription is active

Sync User Audit

To audit synthetic relay users, query Mattermost users with `Position="crossguard-sync"`. Each sync user's `LastName` shows the connection name (e.g., `(via relay-from-a)`), and `Props.CrossguardRemoteUsername` shows the original remote username.

16. Comparison with Alternative Approaches

Capability	Cross Guard (NATS / Azure)	Shared Database	Direct API	Email Bridge	Webhook Relay
Server independence	Full	None (shared DB)	Partial	Full	Full
Network isolation	Yes (NATS in DMZ / Azure private endpoint)	No (DB access)	No (HTTP access)	Yes	No (HTTP access)

Capability	Cross Guard (NATS / Azure)	Shared Database	Direct API	Email Bridge	Webhook Relay
Real-time messaging	Yes (sub-ms NATS / 5-15s Azure)	N/A	Yes	No (minutes)	Yes
Edit/delete sync	Yes	N/A	Possible	No	Manual
Reaction sync	Yes	N/A	Possible	No	No
Thread support	Yes (root_id mapping)	N/A	Possible	No	No
Admin opt-in control	Team + channel level	N/A	N/A	N/A	Per-webhook
Transport security	TLS 1.2+, mTLS, ACLs (NATS) / TLS always, RBAC (Azure)	DB TLS	HTTPS	SMTP TLS	HTTPS
Message authentication	NATS auth / Azure connection string	DB auth	API auth	DKIM/SPF	Shared secret
Resilience	Auto-reconnect	DB failover	Retry logic	Store-and-forward	Manual
Data minimization	Text + optional files (disabled by default, per-connection toggle, type filtering). Azure blobs deleted after processing.	Full DB access	Full API access	Full email	Configurable
Audit trail	Plugin logs + post props	DB audit log	API logs	Mail logs	Webhook logs

17. CDS Deployment Checklist

Hardened Configuration

The following checklist is recommended for Cross Guard deployments in classified or sensitive environments. For a detailed STRIDE threat analysis of each risk, see the [Threat Model](#).

- 1 **Enable `RestrictToSystemAdmins`** : Lock all connection management commands to System Admins. Prevents Team Admins and Channel Admins from enabling relay without organizational approval.
- 2 **Disable `UsernameLookup`** : Force all inbound messages through synthetic sync users. Eliminates impersonation risk ([T-SPOOF-1](#)).
- 3 **Enable TLS with mutual certificate authentication (NATS)**: For NATS connections, configure `tls_enabled` , `client_cert` , `client_key` , and `ca_cert` . Ensures both the plugin and the NATS server verify each other's identity. For Azure connections, TLS is always enabled by the Azure endpoint.
- 4 **Deploy a dedicated transport endpoint**: For NATS, do not share the NATS server with other applications. For Azure, use a dedicated Storage account for Cross Guard traffic. Reduces the risk of message content exposure ([T-INFO-1](#)).
- 5 **Configure transport-level access control**: For NATS, restrict publish and subscribe permissions per subject per client via NATS ACLs. For Azure, use Azure RBAC or SAS tokens to restrict access to the storage account. Ensure each plugin instance can only access the resources it is configured for.
- 6 **Use separate subjects per relay direction (NATS)**: For NATS, configure different subjects for each direction (e.g., `crossguard.a-to-b` and `crossguard.b-to-a`). Prevents transport-level echo. For Azure, use separate queues or storage accounts per direction.
- 7 **Place the transport endpoint in a controlled network segment**: For NATS, deploy the server in a DMZ, enclave, or guard network between the two domains. Firewall rules should allow only NATS traffic (port 4222) between segments. For Azure, use private endpoints or VNet service endpoints to restrict storage account access to authorized networks.
- 8 **Monitor plugin logs**: Watch for anomaly indicators: "Relay semaphore full" (message flood), "Unknown inbound message type" (possible injection), failed resolve warnings (misconfiguration or probing).

- 9 **Audit sync users periodically:** Query users with `Position="crossguard-sync"` to detect unexpected user creation that might indicate unauthorized relay activity.
- 10 **Enforce `crossguard.` subject prefix:** This is validated in configuration. All NATS subjects must start with `crossguard.` to prevent accidental subscription to unrelated NATS traffic.
- 11 **Document and review team name rewrite rules:** Maintain an inventory of all rewrite mappings. Rewrites change message routing and should be reviewed as part of the security configuration.
- 12 **Test connections regularly:** Use the admin console test button or the `POST /api/v1/test-connection` endpoint to verify transport connectivity without affecting running connections.
- 13 **Review the Threat Model:** The [Threat Model page](#) provides a detailed STRIDE analysis of 14 identified threats with severity ratings, code paths, mitigations, and residual risks.

18. References

Overview

Getting started, key concepts, permission model, and federation overview.

Slash Command Reference

All 9 slash commands with arguments, permissions, and examples.

Admin Configuration Guide

Transport connection setup, relay settings, and example configurations.

REST API Reference

All REST endpoints with request/response examples and authentication details.

Threat Model

STRIDE analysis, trust zones, 14 identified threats, and CDS deployment recommendations.